LABORATUVAR 6 · GENEL SÜRÜM · Şişeleme Hattı

CRA Incident Simulation

Çıktı: Incident Workflow

Ad Soyad | Grup | Tarih

Senaryo: Saat **10:15**. Servis hesabında yetkisiz erişim tespit edildi. PLC konfigürasyonu değişmiş olabilir. Makine hâlâ çalışıyor. Vardiya sorumlusu sizsiniz.

Kavram: Bir olayda en değerli iki şey **zaman** ve **kanıt**tır. CRA'nın 24s / 72s / 14 gün yükümlülükleri, iyi bir müdahale akışının doğal kilometre taşlarıdır — ezber değil.

Görev — zaman çizgisini doldurun

1. **10:15 — ilk 15 dk:** Kimi ararsınız? İlk üç eleminiz?

   Önce emniyet: hareketi güvenli duruma al (kontrollü duruş/E-stop, hücreye giriş yasağı); makineyi güvenli varsayma. Ararım: OT/BT güvenlik, bakım/emniyet sorumlusu, üretim müdürü. İlk üç eylem: (1) güvenli duruma al, (2) servis hesabını ve uzak erişimi izole et, (3) ekran/log/ağ kaydını al; resetleme, kapatma yapma.

2. **İlk 2 saat:** Emniyet güvende mi? Neyi korursunuz (kanıt!)? Hangi hesap kapatılır?

   Emniyet: E-stop, ışık perdesi ve STO fonksiyon testi; Safety PLC/PLC konfigürasyonu bilinen iyi yedekle karşılaştırılır. Korunan kanıt: konfigürasyon kopyaları, loglar, VPN/erişim ve oturum kayıtları, zaman damgaları, gerekirse disk/bellek görüntüsü (RESET YOK). Kapatılan: ele geçirilen servis hesabı, paylaşılan/varsayılan parolalar, uzak erişim.

3. **24 saat — CRA erken uyarı:** Hangi bilgi hazır olmalı?

   Hazır olmalı: fark edilme saati, etkilenen ürün/hat/sürüm, kısa olay özeti (servis hesabında yetkisiz erişim), istismar şüphesi, emniyet etkisi (safety fonksiyonu doğrulandı mı), alınan ilk önlemler, etkilenen müşteri/ülke bilgisi.

4. **72 saat — CRA bildirim:** Kök neden, etki, önlem — kim ne yapıyor?

   Kök neden (nasıl girildi: servis hesabı/uzak erişim), etki (hangi konfigürasyon değişti, emniyet etkilendi mi), önlem (hesap kapatma, VPN+MFA, yama). Kim: üretici ürün güvenliği ekibi bildirimi yapar; vardiya sorumlusu bilgi ve log sağlar; bakım fonksiyon testini yapar; yönetim onaylar.

5. **14 gün — son rapor:** Hangi loglar/kayıtlar korunmuş olmalı?

   Oturum/VPN/erişim logları, hesap giriş kayıtları, konfigürasyon öncesi-sonrası kopyaları, emniyet fonksiyonu test sonuçları, olay zaman çizelgesi, düzeltici eylemler ve yama/doğrulama kayıtları; hepsi zaman damgalı ve değiştirilmeden saklanmış olmalı.

En sık hata: "Resetleyip devam edelim" — o düğme, kanıtı sonsuza dek siler. Önce emniyet, hemen sonra kanıt.

Bu föyün çıktısı **Incident Workflow** → Evidence Pack **EP 13 Incident Response** başlığına oturur.